Assessment of the Final Year Project Review

What the 4 November 2026 review gets right, what I verified in the code, and what is worth acting on before the feature freeze

Document reviewed	FINAL_YEAR_PROJECT_REVIEW_2026-11-04.pdf (16 findings, F01–F16)
Reviewed at commit	da49463 — *fix: quieten SQL logging and correct three stale README claims*
Branch	feature/sandesh-frontend-updates
Stack	React 18 (CRA) · Spring Boot 3.4.13 / Java 23 · FastAPI · PostgreSQL · Redis · Chroma
Assessment date	4 November 2026
Feature freeze	5 November 2026

Summary. This review supersedes the earlier PROJECT_REVIEW_AND_RECOMMENDATIONS document and should be the one carried forward. It is based on the current head of the branch rather than an older snapshot, it reports 16 findings instead of 24, and its verification record (207 frontend tests, 290 backend tests) matches the counts I obtain on the same commit — which means the reviewer actually built and ran the project rather than reading it.

I independently confirmed four of its findings in the source. One of them, **F08**, is new relative to the earlier review and is the most valuable thing in the document: an ordinary candidate account can delete the shared vector index. **F01** remains the single highest-severity issue and was still open at the reviewed commit. Both are cheap to close, and both were closed as part of this assessment — see section 4.

1. Standing of the document

Three things distinguish this review from the previous one and raise my confidence in it:

- **It is current.** It cites commit `da49463`, the head of the working branch, so none of its findings are against code that has already been changed.
- **Its evidence is reproducible.** The test counts it reports are the counts the suites actually produce, and at least one finding (F05) was reproduced with a stub model rather than inferred from reading the code.
- **It is better triaged.** Dropping from 24 findings to 16 removed most of the speculative material; what remains is largely specific and locatable, with file and line references that resolve correctly.

The weakness is its remediation plan, which is laid out over four weeks. With the feature freeze one day away that schedule cannot be met, and treating it as a plan rather than as a limitations section would be a mistake. Section 5 covers how I would use it instead.

2. Findings I verified in the source

I checked the four findings that drive the recommendation. All four hold.

F01 Interview session ownership is checked after the AI has already acted — *confirmed*

In `AiProxyController.forwardAndRecord`, the call to the AI service runs first and the ownership check runs afterwards, inside the recorder. When the recorder finds that the caller does not own the session it declines to write and logs a warning — but the response has already been produced and is returned unchanged.

The practical consequence is that a candidate who learns another candidate's session id can submit answers to it, receive the grading, and request the final scorecard. Nothing is persisted, so the only trace is a log line. This is a textbook Broken Object Level Authorization defect (OWASP API1).

```
ResponseEntity<JsonNode> response = forward(path, body, authentication); // AI call FIRST
try {
    recorder.record(authentication.getName(), body, response.getBody()); // check HERE
} catch (Exception e) {
    log.warn(...); // swallowed
}
return response; // returned regardless
```

F08 A candidate can delete the shared knowledge base — *confirmed, and the most important new finding*

The RAG query route forwards the request body to the AI service as an unfiltered `JsonNode`. The AI service's query schema accepts a `force_rebuild` flag, and acting on that flag calls `shutil.rmtree` on the Chroma persistence directory before re-parsing every source document.

The route requires a login but applies no role check, so any signed-in candidate can post `{"question": "...", "force_rebuild": true}` and destroy the index every other user is searching — then have it rebuilt synchronously inside their own request's timeout. The controller's own comment says a reindex is an operator action and that the index route is deliberately not exposed; the query route re-exposed it by accident.

I rate this above the review's own ranking. It is trivially reachable, it affects shared state rather than one user's data, and it would be visible during a demonstration.

```
# ai-service/app/rag/vector_store.py
if force_rebuild:
    if os.path.exists(persist_directory):
        shutil.rmtree(persist_directory)
```

F05 A failed grading is presented to the candidate as a score of zero — *confirmed*

The evaluator rejects a model reply that is not a JSON object, but an empty object passes that check. It then normalizes into a complete scorecard in which every category and every answer scores 0, because `clamp_score(None)` returns 0 — and the result is marked `evaluated: true` with an empty error field.

The candidate is therefore shown 0 out of 100 with nothing on the page indicating that grading never ran. The forgiving behaviour is correct for one missing field among many and wrong for a reply that carried no scores at all. The project already has an honest-blank path for this case; it simply was not reached.

UI The skill-match badge contradicts the summary printed beneath it — *confirmed*

The AI service bands a match percentage at 80 / 60 / 40 (strong, moderate, developing, limited) and writes that word into the summary text it returns. The React page banded the same percentage at 70 / 45 and chose its own label.

A candidate scoring 72% was shown a *Strong Alignment* badge directly above a summary reading “a moderate skill match”. The numbers are not wrong; the two layers simply disagreed about what they mean, which is harder to defend in a report than an outright bug.

3. Triage of all sixteen findings

My ranking differs from the document's in two places: I raise F08, and I lower the whole P2 block to post-submission work.

ID	Finding	Verified?	Verdict
F01	Session ownership checked after the AI acts (BOLA)	Yes	**Fix now — done**
F08	`force_rebuild` reachable by any candidate; deletes the index	Yes	**Fix now — done**
UI	Skill-band thresholds disagree between layers	Yes	**Fix now — done**
F05	Malformed grading JSON becomes a successful zero	Yes	**Fix now — done**
F06	A transient grading failure is cached as the final result	Partly	**Worth fixing**
F07	Fresh install has no RAG bootstrap; health still reports healthy	No	**Demo risk — document**
F10	Answer-quality adaptation applies inconsistent rules	No	**Document as limitation**
F11	RAG API ignores the validated `top_k`	No	**Fix only if k is in the report**
F02–F04	Error handling, filter exception swallowing, logging	No	**Document as limitation**
F12–F16	Bounds, dependency locks, docs, deployment profile	No	**Defer — after submission**

On **F11**: this matters only in one circumstance, but there it matters a great deal. If the dissertation reports a retrieval experiment comparing k=1 against k=5, and the API discards the validated value, then the reported data does not measure what the chapter claims it measures. If no such experiment is written up, the finding is cosmetic.

On **F07**: this is not a correctness bug so much as a demonstration risk. If the submission checklist requires showing the system coming up on a clean machine, an empty index that reports itself healthy will fail that demonstration in a way that looks worse than it is.

4. What was changed in response

Four fixes were implemented and verified. All are narrow, and none alters application behaviour beyond the defect being closed.

F01 — ownership gate moved ahead of the AI call

A new `requireSessionOwnership` method runs before the request reaches the AI service and rejects a session owned by another user with HTTP 403. A session id the database does not know is deliberately allowed through: that is the normal case for an interview that began before the session was persisted, and failing those closed would break a running interview to protect data that was never stored. The gate covers `/interview/answer`, `/interview/finish` and `/interview/model-answer`, the last of which returns the material the candidate is being graded against.

F08 — the rebuild flag is stripped at the gateway

The proxy now removes `force_rebuild` from a RAG query and forwards the rest of the body untouched, so the AI service continues to own its own schema and defaults. The route stays open to every signed-in user, because asking the knowledge base a question is what it is for; only the destructive flag is refused, and the attempt is logged.

F05 — a grading with no scores in it is reported as a failure

A reply carrying no usable number in either the category scores or the per-question scores is now treated as a failed grading and takes the existing honest-blank path, which sets `evaluated: false` and shows the candidate that the scoring step did not finish. An explicit zero from the model still counts as a grade: the guard separates “not graded” from “graded badly”, and booleans are rejected because `float(True)` is 1.0.

Skill bands — the frontend now matches the service

The React thresholds were changed to 80 / 60 / 40 to mirror the four levels the analyzer produces, with a comment in both directions recording that the two must change together or not at all.

Verification

Backend	**303 tests, 0 failures** (was 290) — +9 new `AiProxyControllerTest`, +4 ownership-gate tests
Frontend	**207 tests, 0 failures** (unchanged)
AI service	**141 tests, 0 failures** (was 128) — +13 covering the zero-score guard
Note	The backend suite must be run on JDK 23. JDK 25 breaks Mockito's inline mock maker, which the new controller test relies on.

5. What I recommend leaving alone

F12 through F16 — input bounds, dependency pinning, documentation structure and a production deployment profile — are legitimate observations about production maturity. They are also the findings with the least bearing on how this project will be assessed, and the four-week schedule the document attaches to them cannot be started, let alone finished, before the freeze.

The more useful move is to carry them into the dissertation as a *Known Limitations and Future Work* section, stated plainly and with the reasoning intact. A candidate who can articulate precisely why their system is not production-ready, and what closing each gap would involve, demonstrates better engineering judgement than one who silently leaves the gaps unmentioned. Presenting a four-week remediation plan as if it were scheduled work, on the other hand, invites the obvious question of why it was not done.

The same applies to F10. The inconsistency in how answer quality is judged is real, but changing the adaptation rules the day before a freeze would invalidate whatever interview transcripts have already been collected for the evaluation chapter. It is better described than altered.

Prepared with Claude Code. Findings marked *verified* were confirmed by reading the referenced source and, where stated, by running the test suites; findings marked otherwise are reported as the review states them.